AI METHODOLOGY Ver 1.0

Standard Framework Project

AI 거버넌스 헌장

Governance Charter

Phase 1

산출물 ID : 1.6 Governance Charter

문서 번호	1.6 Governance Charter
버전	v1.0
작성일	2026
작성자	KY Song
분류	CONFIDENTIAL
적용 대상	Standard Framework 프로젝트 전체

Table of Contents

전문 (Preamble) 3
제1장 총칙 4
제 1 조 (목적) 4
제 2 조 (적용 범위) 4
제 3 조 (정의) 4
제2장 AI 거버넌스 원칙 5
제 4 조 (운영 5대 원칙) 5
제 5 조 (인간 중심 원칙) 5
제3장 자율성 및 권한 체계 6
제 6 조 (Authority Level 정의) 6
제 7 조 (승인 체계) 6
제4장 리스크 관리 체계 6
제 8 조 (리스크 분류) 7
제 9 조 (리스크 대응 의무) 7
제5장 감사 및 추적성 8
제 10 조 (Audit Log 의무) 8
제 11 조 (감사 대응) 8
제6장 보안 및 데이터 보호 8
제 12 조 (데이터 분류 및 보호) 9
제 13 조 (접근 통제) 9
제7장 Context 및 변경 통제 10
제 14 조 (Context 관리) 10
제 15 조 (변경 통제) 10
제8장 조직 및 책임 체계 11
제 16 조 (역할 정의) 11
제 17 조 (책임 귀속 원칙) 11
제9장 예외 및 위반 처리 12
제 18 조 (예외 승인) 12
제 19 조 (위반 처리) 12
제10장 지속적 개선 13
제 20 조 (Evolution Loop) 13
제 21 조 (헌장 개정) 13
부록 A 추가 용어 정의 14
부록 B 승인 서명 (Approval Signatures) 15

전문 (Preamble)

본 Standard Framework 프로젝트는 AI-Native 통합 시스템 프레임워크 표준을 구축함으로써, 공공기관 및 민간 조직이 신뢰할 수 있고 통제 가능하며 지속적으로 개선되는 AI 시스템을 개발·운영할 수 있도록 지원하는 것을 목적으로 한다.

AI 기술의 급속한 발전과 공공 분야 디지털 전환의 가속화 속에서, 표준화되지 않은 AI 시스템의 확산은 책임 소재의 불명확, 보안 취약점, 감사 대응의 어려움, 그리고 거버넌스 체계의 부재라는 심각한 위험을 초래하고 있다.

이에 본 프로젝트의 모든 참여자—인간 구성원 및 AI Agent—는 다음에 기술된 거버넌스 헌장의 원칙과 규범을 성실히 준수할 것을 서약하며, 이 헌장은 모든 기술적 표준과 운영 절차의 최상위 기준으로서 효력을 가진다.

제 1 장 총칙

제 1 조 (목적)

1. 본 헌장은 Standard Framework 프로젝트에서 AI 시스템의 설계, 개발, 배포, 운영 전반에 걸쳐 적용되는 거버넌스 원칙과 규범을 정의한다.

2. 본 헌장은 Human과 AI Agent 모두에게 적용되며, 모든 기술 표준 및 운영 절차보다 상위 기준으로서 효력을 가진다.

제 2 조 (적용 범위)

1. 본 헌장은 다음의 모든 주체에 적용된다.

- Standard Framework 프로젝트에 참여하는 모든 Human 구성원 (PM, Architect, 개발자, QA 등)
- 프로젝트 내에서 운영되는 모든 AI Agent (Orchestrator, UIUX, Frontend, Backend, Test, Evolution Agent)
- 프로젝트 산출물을 활용하는 외부 협력 조직

2. LLM 기반 시스템, 의사결정 지원 AI, 자동화된 추천/분류/예측 시스템, 외부 AI API 활용 시스템이 적용 대상이다.

3. 단순 규칙 기반 자동화 및 내부 실험용 프로토타입은 원칙적으로 적용 대상에서 제외된다.

제 3 조 (정의)

용어	정의
Authority Level	AI 시스템의 자율성 수준. L0(분석 지원)~L3(고도 자율)의 4단계로 정의
Global Context	프로젝트 전체에 적용되는 최상위 컨텍스트. Scope, Authority, KPI, Risk, Governance 포함
Agent Context	각 Agent에게 허용된 범위, Skill, Tool 접근 제한을 정의한 컨텍스트
Audit Log	AI 의사결정 및 실행 이력을 추적 가능한 형태로 기록한 로그
Decision Gate	Workflow 진행 중 Human 승인이 필요한 통제 지점
Escalation	Agent가 처리 불가능한 상황을 상위 Human 또는 Orchestrator에 이관하는 절차
Evolution Loop	KPI 모니터링 → 분석 → Context 수정 → 재배포의 지속적 개선 사이클
Release Gate	배포 전 필수 검증 항목을 점검하는 공식 통제 단계
Drift	운영 환경 변화로 인한 AI 모델 성능 저하 현상

제 2 장 AI 거버넌스 원칙

제 4 조 (운영 5 대 원칙)

본 프로젝트의 모든 AI 시스템은 다음 5대 원칙을 설계 단계부터 내재화하여야 한다.

No.	원칙	내용	코드 적용 기준
1	**전략과 실행의 분리**	Global Context와 Agent 실행 코드는 반드시 분리한다. Agent는 Context를 해석하지 않으며 구조화된 제약만 따른다.	Agent 함수 내 전략 판단 로직 직접 작성 금지
2	**최소 권한 원칙**	모든 Agent는 필요한 최소 범위 내에서만 권한을 가진다. Scope 초과 실행은 금지된다.	allowed_scope 외 실행 시 즉시 Escalation
3	**감사 가능성 우선**	모든 의사결정은 추적 가능하여야 한다. 책임(Accountability)은 항상 인간 조직에 귀속된다.	모든 실행 → audit_logs INSERT 필수
4	**리스크 기반 통제**	자율성 수준은 리스크 등급에 비례하여 결정한다. HIGH 이상 리스크는 Human 승인이 필수이다.	Risk Level 체크 모든 Agent 필수 포함
5	**지속적 개선 체계 내재화**	KPI 및 모니터링 결과는 반드시 개선 활동으로 연결된다. Context 수정은 승인 및 회귀 테스트 후 반영한다.	trajectory_logs 기록 후 Evolution Loop 연계

제 5 조 (인간 중심 원칙)

1. AI Agent는 어떠한 상황에서도 인간의 최종 의사결정권을 대체할 수 없다.
2. 모든 최종 승인(Accountable) 권한은 지정된 Human 역할에 귀속된다.
3. AI Agent는 Accountable 역할을 가질 수 없으며, 실행(Responsible) 또는 보조(Support) 역할만 수행한다.
4. Human Override는 언제든지 가능하며, AI 시스템은 이를 방해하거나 우회할 수 없다.

제 3 장 자율성 및 권한 체계

제 6 조 (Authority Level 정의)

Level	명칭	정의	자동 실행	승인 주체
L0	분석 지원	Human 전면 결정, AI는 분석 지원만 수행	불가	불필요
L1	추천 수준	AI 추천 제공, 최종 결정은 Human 승인 필수	불가	Business Owner
L2	조건부 자동	사전 정의된 조건 내 자동 수행 가능	조건부 가능	Governance Board
L3	고도 자율	사후 모니터링 중심, 고도 자율 실행	가능	Executive + Governance Board 공동

⚠ 본 프로젝트의 현재 Authority Level은 L1이다. L2 이상으로의 변경은 Governance Board 공식 승인이 필요하다.

제 7 조 (승인 체계)

1. 모든 AI 시스템은 배포 전 Authority Level을 공식 승인 받아야 한다.
2. Authority Level 변경은 별도의 위험성 평가(Risk Assessment) 수행 후 상위 승인 체계를 통해 처리한다.
3. 승인 없는 자동 실행 코드는 어떠한 경우에도 배포할 수 없다.
4. Decision Gate에서 Human 승인이 거부된 경우, AI Agent는 해당 작업을 즉시 중단하고 이유를 Audit Log에 기록한다.

제 4 장 리스크 관리 체계

제 8 조 (리스크 분류)

등급	기준	통제 수준	대응 방식
Low	내부 분석 지원 수준	기본 통제 체계 적용	표준 모니터링
Medium	사용자 의사결정 보조	표준 통제 + 주기적 검토	이상 탐지 시 알림
High	사용자 영향도 높음 (재무, 법적 영향)	강화된 통제 + Human 승인 필수	즉시 보고 + 대응
Critical	생명, 안전, 법적 책임 직접 영향	최고 수준 통제 + 즉시 에스컬레이션	자동 중단 + 긴급 대응

제 9 조 (리스크 대응 의무)

1. 모든 AI 시스템은 배포 전 Risk Assessment를 수행하여야 한다.
2. Bias, Hallucination, Drift, Prompt Injection에 대한 방어 체계를 반드시 구현하여야 한다.
3. High 이상 리스크 발생 시 해당 Agent는 자동으로 실행을 중단하고 Orchestrator에 에스컬레이션하여야 한다.
4. KPI Threshold 초과 또는 Drift 감지 시 72시간 이내에 Root Cause Analysis를 수행하여야 한다. (단, P2 On-risk 발동 시 Human 알림은 1시간 이내 선행 — 1.5 HITL 구조 참조)

제 5 장 감사 및 추적성

제 10 조 (Audit Log 의무)

1. 모든 AI Agent의 실행 결과는 audit_logs 테이블에 반드시 기록되어야 한다.
2. Audit Log에는 다음 정보가 포함되어야 한다.
   - 실행 Agent 식별자 및 버전
   - 실행 시각 (UTC 기준)
   - 입력 데이터 (데이터 분류 등급 포함)
   - 의사결정 근거 및 결과
   - Human 승인 여부 및 승인자
   - 에스컬레이션 발생 여부
3. Audit Log에 대한 DELETE, UPDATE 작업은 어떠한 경우에도 허용되지 않는다.
4. Audit Log는 최소 5년간 보관되어야 한다.

제 11 조 (감사 대응)

1. 외부 감사 요청 시 72시간 이내에 관련 Audit Log를 제공할 수 있어야 한다.
2. AI 의사결정 경로는 비기술 담당자도 이해할 수 있는 형태로 설명 가능하여야 한다.
3. Agent 버전 이력은 항상 추적 가능하도록 관리하여야 한다.

제 6 장 보안 및 데이터 보호

제 12 조 (데이터 분류 및 보호)

1. 모든 데이터는 Public / Internal / Sensitive / Restricted 4등급으로 분류하여 관리한다.
2. Sensitive 이상 데이터는 저장 및 전송 시 반드시 암호화한다.
3. Restricted 데이터는 API 응답 시 마스킹 또는 익명화 처리 후 제공한다.
4. 데이터 최소 수집 원칙을 준수하며, 목적 외 데이터 수집을 금지한다.

제 13 조 (접근 통제)

1. 역할 기반 접근 통제(RBAC)를 모든 API 엔드포인트에 적용한다.
2. 관리자 권한은 이중 승인 체계를 통해서만 부여된다.
3. API Key, Secret, 비밀번호는 코드에 직접 작성할 수 없으며 환경변수로 관리한다.
4. Prompt Injection 방어 체계를 구현하고, 모든 외부 입력값은 검증 후 사용한다.

제 7 장 Context 및 변경 통제

제 14 조 (Context 관리)

1. 모든 Agent는 실행 전 Global Context를 반드시 로드하여야 한다.
2. Agent Context는 Global Context로부터 자동 생성되어야 하며, 직접 수정은 금지된다.
3. Runtime Context는 Global 또는 Agent Context를 변경할 수 없다.
4. 모든 Context는 버전 번호를 포함하며, 변경 이력(Change Log)을 기록하여야 한다.

제 15 조 (변경 통제)

1. Global Context 변경은 다음 절차를 반드시 준수한다.

단계	활동	내용	담당
1	**변화 감지**	KPI 이상, Drift 탐지, 규제 변경 등 트리거 발생	Monitoring Agent
2	**위험성 평가**	변경이 가져올 영향 범위 및 리스크 평가	AI Architect
3	**수정 제안**	Context 수정 내용 문서화 및 제안서 작성	Evolution Agent (보조)
4	**Governance 승인**	Governance Board 검토 및 승인	Governance Board
5	**재생성 및 테스트**	Agent Context 자동 재생성 + Regression Test	Test Agent
6	**재배포**	승인 완료 후 배포	Back-H (Backend Developer)

2. 회귀 테스트 없이 변경된 Context를 배포할 수 없다.

제 8 장 조직 및 책임 체계

제 16 조 (역할 정의)

역할	승인 권한	주요 책임
Executive Sponsor	L3 최종 승인	최종 책임자, 전략 방향 결정
AI Governance Board	L2 정책 승인	정책 승인, Release Gate 승인, Context 변경 승인
Business Owner	L1 운영 승인	비즈니스 요구사항 정의, KPI 승인
AI Architect	기술 제안	아키텍처 설계, Authority Level 제안, 기술 표준 정의
Back-H (Backend Developer)	배포 실행	배포 및 운영 안정성 책임
Compliance Officer	규제 검토	법적/윤리적 준수 검토

제 17 조 (책임 귀속 원칙)

1. 모든 최종 책임(Accountable)은 지정된 인간 역할에 귀속되며, AI Agent에게 귀속될 수 없다.
2. AI Agent는 실행 책임(Responsible) 또는 보조(Support) 역할만 수행한다.
3. AI Agent의 오류로 인한 피해에 대한 책임은 해당 Agent를 승인한 Human에게 귀속된다.

제 9 장 예외 및 위반 처리

제 18 조 (예외 승인)

1. 본 헌장의 규정을 벗어나는 운영은 Governance Board의 사전 승인을 받아야 한다.
2. 예외 승인 신청 시 다음 사항을 문서화하여야 한다.
   - 예외 내용 및 사유
   - 영향 범위 분석
   - 완화 조치(Mitigation Plan)
   - 유효 기간 (최대 90 일)
3. 예외 승인 후에도 Audit Log 기록 의무는 유지된다.
4. 동일한 예외가 3회 이상 반복될 경우 구조적 개선 대상으로 전환하여야 한다.

제 19 조 (위반 처리)

위반 유형	즉각 조치	사후 처리	재발 방지
Audit Log 누락	배포 차단	누락 로그 재구성	로그 자동 검증 체계 구축
Scope 초과 실행	즉시 실행 중단	영향 범위 분석 + 복구	Scope 검증 로직 강화
승인 없는 자동 실행	롤백 + 격리	재승인 절차 진행	승인 게이트 강화
Context 무단 수정	즉시 복원	변경 이력 감사	변경 권한 재설정
데이터 보안 위반	즉시 격리	피해 범위 평가 + 보고	보안 체계 전면 점검

제 10 장 지속적 개선

제 20 조 (Evolution Loop)

1. 운영 중 수집된 KPI 및 모니터링 데이터는 반드시 개선 활동으로 연결되어야 한다.
2. Evolution Loop는 다음 단계로 운영된다.

단계	활동	내용	주체
1	모니터링	KPI, Drift, 이상 징후 지속 감시	Monitoring Agent
2	분석	Root Cause Analysis 수행	AI Architect + Test Agent
3	Risk 재평가	변경 필요성 및 리스크 재평가	Governance Board
4	Context 수정	Global Context 수정 제안 및 승인	Evolution Agent + 승인
5	재생성	Agent Context 자동 재생성	Orchestrator Agent
6	테스트	Regression Test 수행 필수	Test Agent
7	재배포	승인 완료 후 배포	Back-H (Backend Developer)

제 21 조 (헌장 개정)

1. 본 헌장은 연 1회 정기 검토를 수행하며, 필요 시 임시 개정할 수 있다.
2. 헌장 개정은 Governance Board의 승인을 필요로 하며, 개정 이력을 문서화하여야 한다.
3. 헌장 개정 시 영향을 받는 모든 관련 표준 및 운영 절차를 함께 검토하여야 한다.

부록 A 추가 용어 정의

용어	정의
Human-in-the-Loop	AI 의사결정 과정에 인간이 직접 개입하여 검토·승인하는 구조
Guardrail	AI가 허용 범위를 벗어난 행동을 하지 못하도록 하는 기술적 제약 장치
Trajectory Log	Agent 실행의 전체 경로(입력→처리→출력)를 기록한 상세 로그
Zero-Trust	내부 네트워크도 신뢰하지 않고 모든 접근을 검증하는 보안 원칙
RBAC	Role-Based Access Control. 역할 기반 접근 통제 체계
Regression Test	변경 사항이 기존 기능에 영향을 미치지 않음을 검증하는 테스트
Prompt Injection	악의적인 입력값으로 AI 시스템의 동작을 조작하려는 공격 기법
Least Privilege	시스템 구성 요소가 필요한 최소한의 권한만 보유하도록 하는 원칙
Explainability	AI 의사결정 과정을 인간이 이해할 수 있도록 설명하는 능력
Model Drift	시간이 지남에 따라 AI 모델의 성능이 저하되는 현상

부록 B 승인 서명 (Approval Signatures)

본 AI 거버넌스 헌장에 서명함으로써, 서명자는 본 문서의 내용을 충분히 이해하고 이를 성실히 준수할 것을 서약한다.

역할	성명	서명	날짜
Executive Sponsor			
AI Governance Board			
Business Owner (PM)			
AI Architect			
Compliance Officer			
문서 작성자	KY Song		2026

본 헌장은 Standard Framework 프로젝트의 최상위 거버넌스 문서이다.

GC-STD-2026-001 · v1.0 · CONFIDENTIAL